

Marco integrativo GQM + PRAGMATIC para indicadores SQUARE

De los objetivos nacionales a las métricas técnicas sin perder piezas por el camino

1. Introducción

Este documento define el marco integrativo que combina:

- La metodología Goal–Question–Metric (GQM) para asegurar la trazabilidad desde los objetivos nacionales y organizativos hasta las métricas técnicas.
- Los criterios PRAGMATIC (Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente, Rentable) para evaluar la calidad de cada métrica.

Se aplica sobre el conjunto de indicadores propuestos en el informe SQUARE de requisitos de seguridad, con la ambición de que cada número responda a un “¿para qué?” y no solo a un “¿cuánto?”.

2. Recordatorio: indicadores SQUARE de referencia

Tomamos como base los indicadores descritos en el informe SQUARE, agrupados en tres niveles:

1. Cobertura de requisitos
2. Cobertura de funciones críticas con requisitos explícitos.
3. Cobertura de amenazas de alto impacto con requisitos mitigadores.
4. Calidad de requisitos
5. Proporción de requisitos que cumplen criterios de buena ingeniería (claros, verificables, trazables).
6. Porcentaje de requisitos que superan la inspección sin observaciones críticas.
7. Número de iteraciones de revisión necesarias hasta la aceptación.
8. Alineamiento riesgo–requisito y contexto
9. Distribución de requisitos (esencial/condicional/opcional) frente a nivel de riesgo.
10. Número de activos críticos sin requisitos asociados.
11. Uso de métricas, cuadros de mando e integración con incidentes.
12. Dimensiones agregadas para el IGM (GOV, RISK, REQ, MET, CAP) y estimaciones de ROI.

Cobertura de amenazas de alto impacto con requisitos mitigadores.

Calidad de requisitos

Número de iteraciones de revisión necesarias hasta la aceptación.

Alineamiento riesgo–requisito y contexto

Sobre estos indicadores se construye el andamiaje GQM + PRAGMATIC.

3. Metodología GQM aplicada a SQUARE

La metodología GQM se articula en tres niveles:

13. Goal (Objetivo): qué queremos mejorar o comprender.
14. Question (Pregunta): qué cuestiones concretas debemos formular para saber si nos acercamos al objetivo.
15. Metric (Métrica): qué datos cuantitativos o cualitativos registramos para responder a las preguntas.

Para el contexto SQUARE en España, proponemos tres objetivos GQM de alto nivel:

Objetivo G1 – Madurez de requisitos de seguridad

Goal G1

Analizar y mejorar la **madurez de la ingeniería de requisitos de seguridad** en organizaciones críticas para reducir el riesgo residual y aumentar la resiliencia digital.

Preguntas clave (Q):

- Q1.1 ¿Hasta qué punto las funciones de negocio críticas cuentan con requisitos de seguridad explícitos y actualizados?
- Q1.2 ¿En qué medida las amenazas y riesgos identificados quedan cubiertos por requisitos específicos?
- Q1.3 ¿Qué calidad tienen los requisitos de seguridad (claridad, verificabilidad, trazabilidad)?
- Q1.4 ¿Cuántas iteraciones son necesarias para alcanzar una especificación de requisitos aceptable?

Métricas (M) asociadas (ejemplos):

- M1.1 Cobertura de funciones críticas con requisitos de seguridad.
- M1.2 Cobertura de amenazas de alto impacto con requisitos mitigadores.
- M1.3 Porcentaje de requisitos “bien formados” según checklist.
- M1.4 Porcentaje de requisitos que superan la revisión sin observaciones críticas.
- M1.5 Número medio de iteraciones de revisión por proyecto.

Objetivo G2 – Alineamiento con gestión de riesgos y normativa

Goal G2

Evaluar y mejorar el **alineamiento entre requisitos de seguridad, gestión de riesgos y marcos normativos (NIS2, ENS, ISO, etc.)**, para asegurar coherencia y cumplimiento eficaz.

Preguntas clave:

- Q2.1 ¿Hasta qué punto existe trazabilidad entre activos, riesgos, requisitos y controles?
- Q2.2 ¿En qué medida los requisitos de seguridad reflejan las obligaciones de NIS2, ENS y otros marcos sectoriales?
- Q2.3 ¿Los requisitos se revisan tras incidentes, cambios significativos o auditorías?
- Q2.4 ¿Se utilizan métricas para comprobar el cumplimiento de mandatos (IGM, indicadores normativos)?

Métricas asociadas:

- M2.1 Número de activos críticos sin requisitos de seguridad asociados.
- M2.2 Porcentaje de riesgos de alto impacto con requisitos esenciales asignados.
- M2.3 Porcentaje de requisitos mapeados explícitamente a marcos normativos.
- M2.4 Frecuencia de revisión de requisitos tras incidentes o cambios.
- M2.5 Índice de Gestión de Mandato (IGM) para requisitos de seguridad.

Objetivo G3 – Valor económico y mejora continua

Goal G3

Comprender y optimizar el **valor económico** de la ingeniería de requisitos de seguridad, articulando un caso sólido de negocio que fomente la mejora continua.

Preguntas clave:

- Q3.1 ¿Cuál es el coste total asociado al ciclo de vida de los requisitos de seguridad?
- Q3.2 ¿Qué evidencias hay de beneficios (incidentes evitados, retrabajo reducido, auditorías más eficientes)?
- Q3.3 ¿Cómo se relaciona el IGM con indicadores de resultados (incidentes, vulnerabilidades, sanciones, etc.)?
- Q3.4 ¿Qué ROI aproximado puede atribuirse a la inversión en requisitos de seguridad?

Métricas asociadas:

- M3.1 Coste anual del proceso de requisitos de seguridad.
- M3.2 Beneficios estimados por incidentes evitados/mitigados.
- M3.3 Beneficios por reducción de retrabajo.
- M3.4 Beneficios en auditorías/certificaciones.
- M3.5 ROI de requisitos de seguridad.
- M3.6 Correlaciones entre IGM y resultados (incidentes, sanciones, etc.).

4. Criterios PRAGMATIC: evaluación de la calidad de las métricas

Cada métrica se evalúa según los criterios PRAGMATIC:

16. Predictivo – ¿Ayuda a anticipar resultados futuros (incidentes, fallos, incumplimientos)?
17. Relevante – ¿Está alineada con objetivos clave (G1, G2, G3) y prioridades nacionales/organizativas?
18. Accionable – ¿Sugiere acciones claras cuando el valor es bajo o insatisfactorio?
19. Genuino – ¿Refleja la realidad y no solo artefactos burocráticos o datos maquillados?
20. Significativo – ¿Es suficientemente comprensible e importante como para influir en decisiones?
21. Preciso – ¿Puede medirse con un nivel razonable de exactitud y consistencia?
22. Oportuno – ¿Puede actualizarse con la frecuencia necesaria para ser útil?
23. Independiente – ¿No se solapa excesivamente con otras métricas ni está dominada por ellas?
24. Rentable – ¿El coste de obtenerla es razonable comparado con el valor que aporta?

Se recomienda puntuar cada criterio de 0 a 2:

- 0: No cumple
- 1: Cumple parcialmente
- 2: Cumple claramente

Esto genera una **puntuación PRAGMATIC** de 0 a 18 por métrica.

5. Selección y priorización de métricas

No todas las métricas deben tener el mismo protagonismo. El marco propone:

25. Evaluar todas las métricas candidatas con PRAGMATIC.
26. Clasificarlas según su puntuación total y, si se desea, por criterios clave (por ejemplo, Predictivo y Accionable).
27. Seleccionar un núcleo duro de métricas con alto puntaje PRAGMATIC para el cuadro de mando principal, dejando el resto como métricas de apoyo o análisis puntual.

Ejemplo de decisión:

- Métrica M1.1 (Cobertura de funciones críticas) obtiene 16/18 → métrica central.
- Métrica M3.2 (Beneficios por incidentes evitados) obtiene 11/18 → útil, pero con cautela por la estimación.
- Métrica M2.4 (Frecuencia de revisión tras incidentes) obtiene 14/18 → buena candidata para seguimiento de mejora continua.

6. Integración con el IGM

El Índice Global de Madurez (IGM) se alimenta principalmente de métricas de proceso (M1.x, M2.x, M4.x en el informe original), mientras que algunas métricas económicas y de resultado (M3.x) se usan para análisis complementario.

El marco GQM + PRAGMATIC orienta:

- Qué métricas entran en el IGM (alta calidad PRAGMATIC, alta relevancia para G1 y G2).
- Qué métricas se reservan para análisis de negocio y ROI (foco en G3).
- Cómo comunicar la diferencia entre madurez de proceso (IGM) y desempeño en resultados (incidentes, ROI).

7. Uso nacional y sectorial

Aplicado a escala país:

- Los objetivos G1, G2 y G3 pueden alinearse con la Estrategia Nacional de Ciberseguridad y con las obligaciones de NIS2.
- Las métricas GQM se convierten en un vocabulario común para comparar sectores y territorios.
- PRAGMATIC actúa como filtro para evitar “vanity metrics” y priorizar aquello que realmente ayuda a gobernar.

La principal virtud del marco es la trazabilidad explícita: desde los objetivos políticos y estratégicos hasta los datos técnicos que se recogen en sistemas, proyectos y equipos.

8. Conclusión

El matrimonio entre GQM y PRAGMATIC, aplicado sobre indicadores SQUARE, ofrece una vía sensata para que España pase de contar incidentes a medir, con un mínimo de elegancia, la calidad de sus requisitos de seguridad.

Los objetivos clarifican el “para qué”; las preguntas iluminan el “qué”; las métricas, evaluadas críticamente, nos dicen el “cuánto” y el “qué hacer ahora”.